

OWASP ASVS v4.0 & MITRE ATT&CK Control Matrix

Zero-Trust Secure Backend & Identity Threat Detection · Technical Documentation

Security Control Mapping & Compliance Matrix

This document maps all architectural, cryptographic, and behavioral security controls implemented in the **Zero-Trust Secure Evidence Exchange** to the threats identified in [threat-model.md](#), the **OWASP Application Security Verification Standard (ASVS) v4.0**, and the **MITRE ATT&CK Enterprise Matrix (Identity & Access Techniques)**.

Control Mapping Matrix

Control ID	Control Name	Target Threat(s)	OWASP ASVS v4.0 Requirement	MITRE ATT&CK Technique	Implementation Module	Verification Method
CTL-01	WebAuthn / Passkeys Primary AuthN	THR-SPOOF-01, THR-DOS-01	V2.1.1 (Verify user authentication using modern authenticator standards like FIDO2/WebAuthn)	T1110 (Brute Force), T1078 (Valid Accounts)	src/auth/webauthn/	Automated ceremony tests via Playwright virtual authenticator & Pytest challenge-response validation.
CTL-02	OAuth2 / OIDC Federated Fallback	THR-SPOOF-01	V2.7.1 (Verify federated identity providers conform to OpenID Connect Core 1.0)	T1078 (Valid Accounts)	src/auth/oauth/	Authlib OIDC signature validation & nonce/state verification unit tests.
CTL-03	Short-Lived Access Tokens (JWT)	THR-SPOOF-01, THR-ELEV-01	V3.5.2 (Verify stateless tokens have short validity periods, e.g. 15 minutes)	T1550.001 (Application Access Token)	src/auth/tokens/	Expiration assertion tests & claims validation.
CTL-04	Rotating Refresh Token Family & Reuse Revocation	THR-SPOOF-02	V3.5.3 (Verify token rotation and immediate invalidation upon reuse detection)	T1078 (Valid Accounts), T1552 (Unsecured Credentials)	src/auth/tokens/service.py	Pytest simulating replay of a retired refresh token, verifying entire token family is revoked.
CTL-05	Open Policy Agent (OPA) Fine-Grained RBAC/ABAC	THR-TAMP-01, THR-	V4.1.1 (Verify access control is enforced on a trusted service layer), V4.1.3	T1078 (Valid Accounts)	policies/case_access.rego, src/authz/	Rego policy unit tests + FastAPI endpoint

Control ID	Control Name	Target Threat(s)	OWASP ASVS v4.0 Requirement	MITRE ATT&CK Technique	Implementation Module	Verification Method
		ELEV-02	(Verify least privilege)			authorization matrices.
CTL-06	Fail-Secure Authorization Engine Default	THR-INFO-02	V4.1.5 (Verify that access control decisions fail securely with DENY by default)	T1562.001 (Disable or Modify Tools)	src/authz/client.py	Explicit failure simulation test: mock OPA connection timeout/500 and assert HTTP 403 Forbidden.
CTL-07	Vault Transit Envelope Encryption	THR-INFO-01	V6.2.1 (Verify all sensitive data is encrypted at rest using strong algorithms, e.g. AES-256-GCM)	T1005 (Data from Local System), T1552 (Unsecured Credentials)	src/crypto/envelope.py	Pytest asserting raw PostgreSQL query returns ciphertext and wrapped DEK, not plaintext.
CTL-08	Field-Level PII Encryption	THR-INFO-01	V6.2.2 (Verify sensitive PII fields are individually encrypted prior to storage)	T1005 (Data from Local System)	src/crypto/field_crypto.py	Pytest field round-trip validation and database direct column inspection.
CTL-09	Append-Only Immutable Audit Logging	THR-REP-01, THR-TAMP-02	V8.1.1 (Verify audit logs record actor, timestamp, action, and resource)	T1562.002 (Disable Windows Event Logging / Tamper Audit)	src/api/audit.py, src/models/audit_log.py	Integration test asserting every state mutation and read generates an immutable audit record.
CTL-10	Behavioral Identity Anomaly Detection (IsolationForest)	THR-SPOOF-01, THR-DOS-01	V2.2.1 (Verify protection against automated attacks and anomalous access patterns)	T1110.003 (Password Spraying), T1621 (MFA Request Generation / Push-Bombing)	src/detection/, src/telemetry/	Multi-category synthetic traffic benchmark evaluating Precision, Recall, and F1 across all attack vectors.
CTL-11	Continuous SAST & DAST Verification in CI	THR-ELEV-01, THR-TAMP-01	V14.2.1 (Verify automated security testing is integrated into the build pipeline)	T1190 (Exploit Public-Facing Application)	.github/workflows/ci.yml	Semgrep rulesets (p/default, p/owasp-top-ten) and OWASP ZAP baseline scan execution in

Control ID	Control Name	Target Threat(s)	OWASP ASVS v4.0 Requirement	MITRE ATT&CK Technique	Implementation Module	Verification Method
						GitHub Actions.

Synthetic Data Integrity & Verification Statement

In compliance with zero-trust privacy principles: - **No production credentials, real private keys, or real human PII exist anywhere in this repository.** - All user accounts, forensic case notes, IPs, MAC addresses, and subject profiles are generated synthetically by deterministic generation fixtures (`scripts/generate_traffic/`). - Documentation, benchmark numbers, and evaluation metrics are produced through real, empirical execution of local test pipelines.